

ОТЧЁТ ПО ПРАКТИЧЕСКОЙ РАБОТЕ

«Misconfiguration и IDOR»

Цель работы: исследовать Misconfiguration и IDOR в локальной учебной среде, исправить нарушение контроля доступа и проверить результат.

Выполнил: Аньшин Сергей

Группа: ИСП-406

1. Подготовка учебной среды

Проверена работа Apache, затем просмотрена структура lesson1 и определены разделы для дальнейшей работы.

```
sudo apt install virtualbox-guest-x11
Вы действительно хотите установить? (Н/д)d

(student@codeby)-[~]
$ VBoxClient --clipboard
Команда «VBoxClient» не найдена, но может быть установлена с помощью:
sudo apt install virtualbox-guest-x11
Вы действительно хотите установить? (Н/д)yes

(student@codeby)-[~]
$
```

Рисунок 1 — Проверка состояния веб-сервера Apache в терминале.

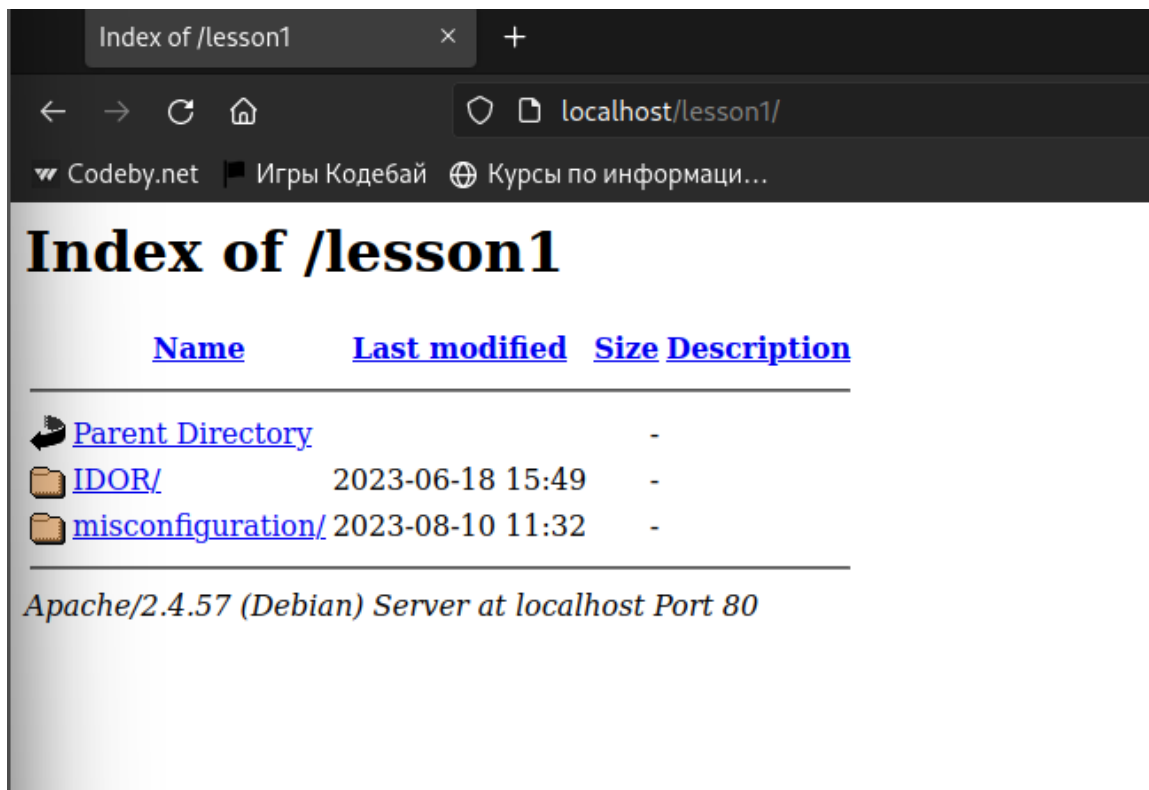


Рисунок 2 — Просмотр структуры каталога lesson1.

2. Проверка Misconfiguration

Открыт Tiny File Manager в учебном разделе misconfiguration. После входа был получен доступ к просмотру каталогов веб-сервера, что демонстрирует риск небезопасной конфигурации служебного интерфейса.

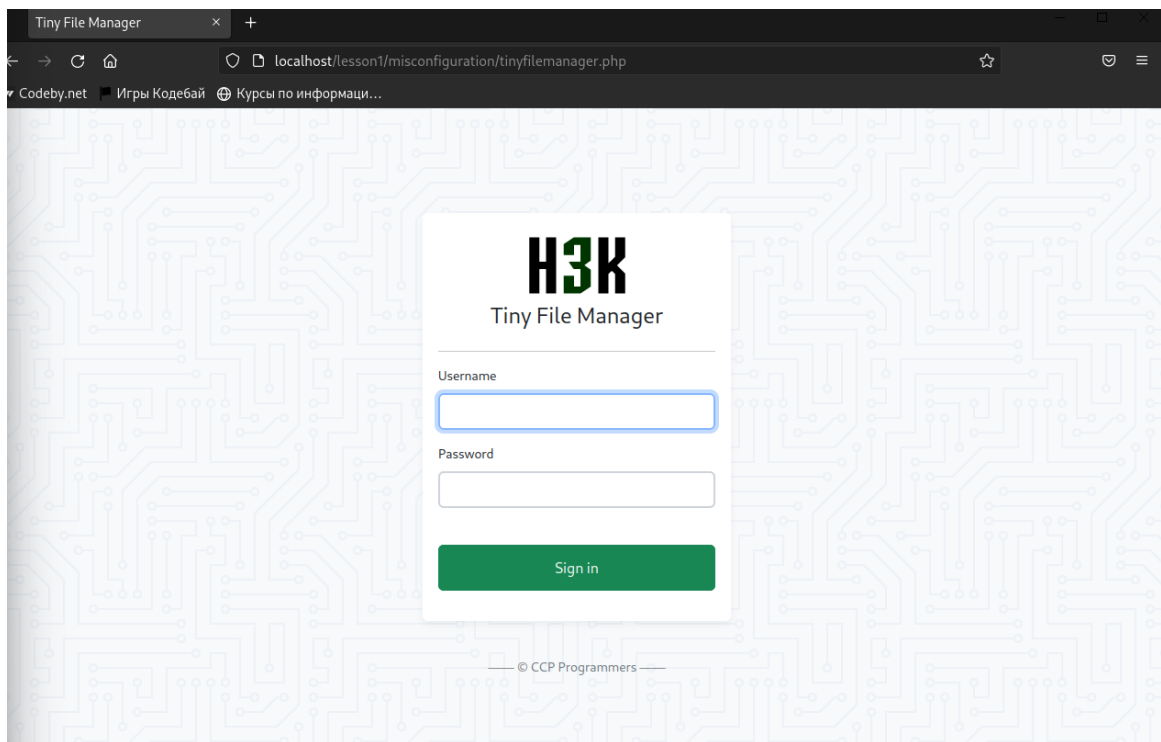


Рисунок 3 — Открытие Tiny File Manager.

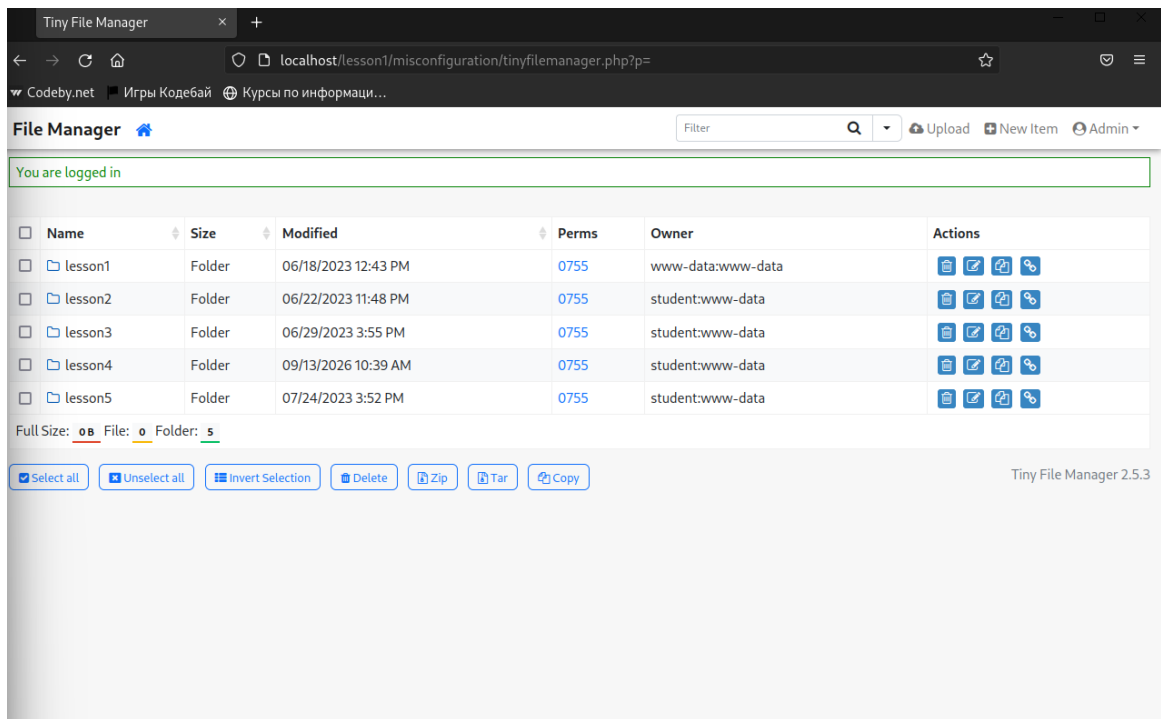


Рисунок 4 — Вход в Tiny File Manager и просмотр каталогов.

3. Подготовка к проверке IDOR

Открыт учебный сайт технической поддержки. Проверена регистрация и выполнен вход под созданной учётной записью student1.

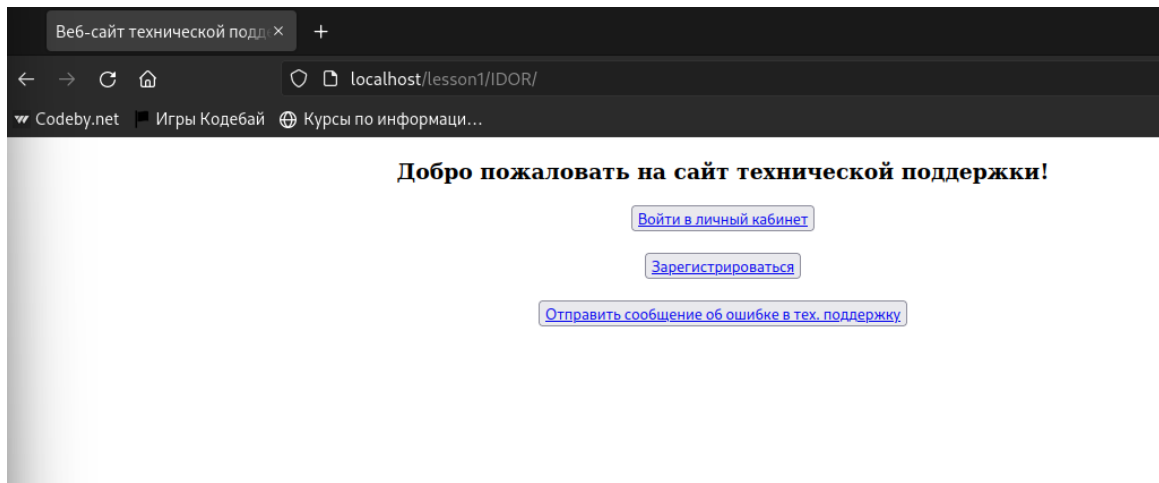


Рисунок 5 — Главная страница учебного сайта технической поддержки.

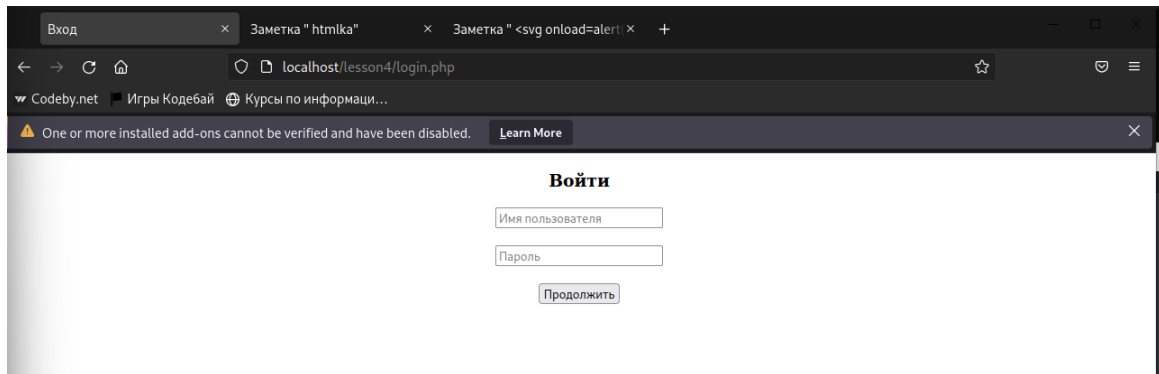
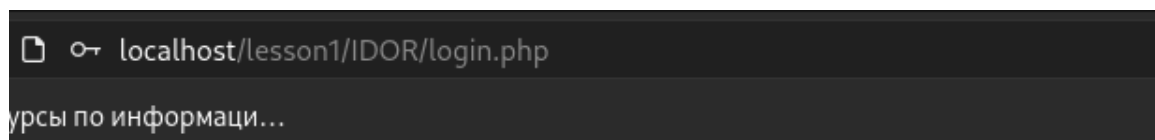


Рисунок 6 — Форма регистрации пользователя.

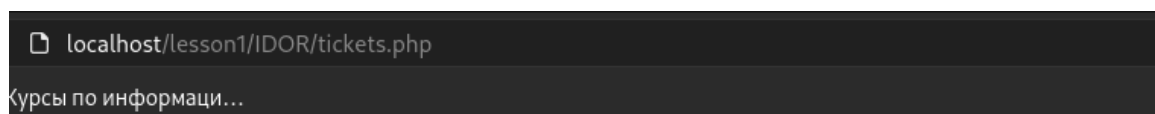


Войти в личный кабинет

Рисунок 7 — Вход под учётной записью student1.

4. Создание тестового обращения

После входа создан тестовый тикет Test ticket с сообщением Test message. Он получил идентификатор id=3.



Открытые обращения

Создать обращение

Рисунок 8 — Создание нового обращения.

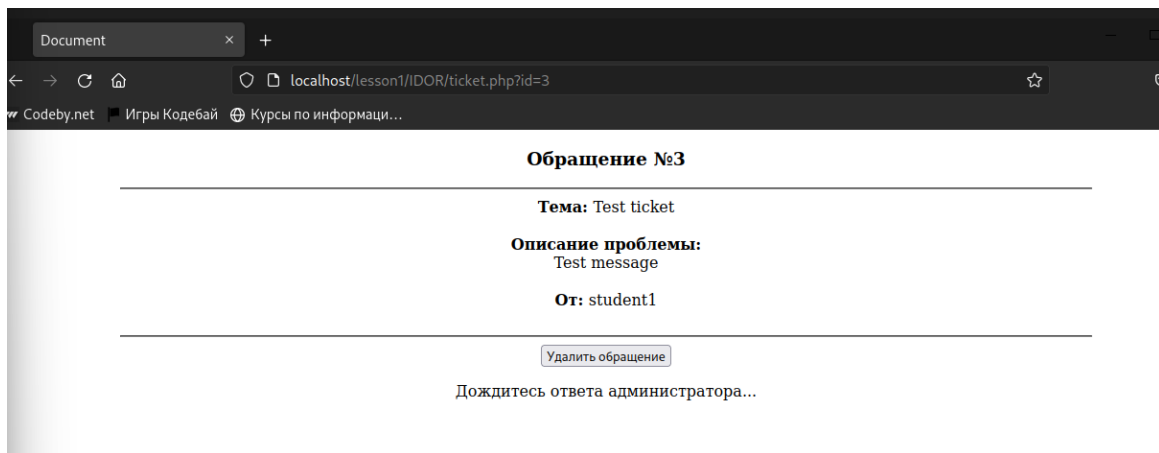


Рисунок 9 — Собственное обращение №3.

5. Подтверждение IDOR

Параметр `id` в адресной строке был изменён с 3 на 2. До исправления приложение показало чужое обращение, что подтвердило отсутствие проверки владельца объекта.

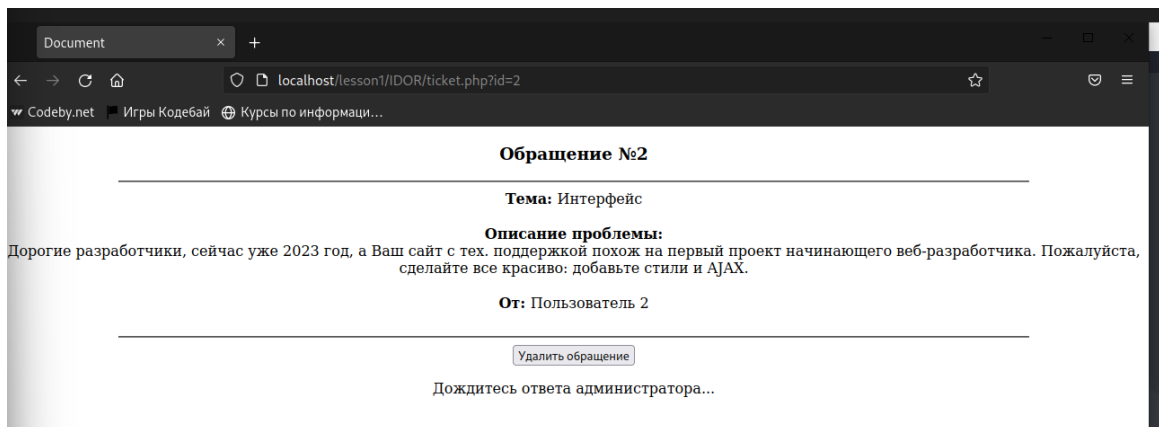


Рисунок 10 — До исправления: доступ к чужому обращению `id=2`.

6. Исправление IDOR

В `ticket.php` к запросам `SELECT` и `DELETE` добавлена проверка поля `created_by` для текущего пользователя.

```
$sql = "SELECT * FROM tickets WHERE id=$id AND created_by='$user'";
```

```
$sql = "DELETE FROM tickets WHERE id=$id AND created_by='$user'";
```

```
GNU nano 7.2
<?php
$servername = "127.0.0.1";
$username = "root";
$password = "c0d3by";
$dbName = "lesson1";

$link = mysqli_connect($servername, $username, $password, $dbName);

if (isset($_POST['submit'])) {
    $id = $_POST['id'];
    $sql = "DELETE FROM tickets WHERE id=$id AND created_by='user'";
    mysqli_query($link, $sql);
    header("Location: /lesson1/IDOR/tickets.php");
}

?>
```

Рисунок 11 — Изменение запроса DELETE.

```
Файл Действия Правка Вид Справка
GNU nano 7.2
<?php
$servername = "127.0.0.1";
$username = "root";
$password = "c0d3by";
$dbName = "lesson1";

$link = mysqli_connect($servername, $username, $password, $dbName);

if (isset($_POST['submit'])) {
    $id = $_POST['id'];
    $sql = "DELETE FROM tickets WHERE id=$id AND created_by='user'";
    mysqli_query($link, $sql);
    header("Location: /lesson1/IDOR/tickets.php");
}

?>

<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Document</title>
</head>
<body>
    <div align="center">
        <?php
            $id = $_GET['id'];
            $user = $_COOKIE['User'];
            $sql = "SELECT * FROM tickets WHERE id=$id AND created_by='$user'";
            $res = mysqli_query($link, $sql);

            if (mysqli_num_rows($res) == 0) {
                echo "<b>Not found</b>";
            } else {
                while ($rows = mysqli_fetch_array($res)) {
                    echo "<h3> Обращение №" . $rows['id'] . "</h3>";
                    echo "<hr style='width: 80%;'>";
                    echo "<b>Тема: </b>" . $rows['subject'] . "<br><br>";
                    echo "<b>Описание проблемы: </b><br>" . $rows['problem'] . "<br><br>";
                    echo "<b>От: </b>" . $rows['created_by'] . "<br><br>";
                    echo "<hr style='width: 80%;'>";
                    echo "<form action=\"/lesson1/IDOR/ticket.php\" method=\"POST\">";
                    echo "<input type=\"hidden\" value=\"" . $id . "\" name=\"id\">";
                    echo "<button type=\"submit\" name=\"submit\" value=\"submit\">Удалить обращение</button>";
                    echo "</form>";
                    echo "<p>Дождитесь ответа администратора... </p>";
                }
            }
        ?>
    </div>
</body>
</html>
```

Рисунок 12 — Изменение запроса SELECT.

7. Проверка внесённых изменений

После сохранения проверена итоговая строка SELECT командой `grep`. PHP-файл также проверялся командой `php -l`; синтаксических ошибок обнаружено не было.

```
(student@codeby)~[~]
$ sudo nano /var/www/html/lesson1/IDOR/ticket.php

(student@codeby)~[~]
$ grep -n "SELECT.*tickets" /var/www/html/lesson1/IDOR/ticket.php
30:     $sql = "SELECT * FROM tickets WHERE id=$id AND created_by='$user'";

(student@codeby)~[~]
$
```

Рисунок 13 — Проверка SELECT командой grep.

8. Контрольное тестирование

Собственное обращение `id=3` осталось доступным. При открытии чужого обращения `id=2` приложение стало выводить Not found.

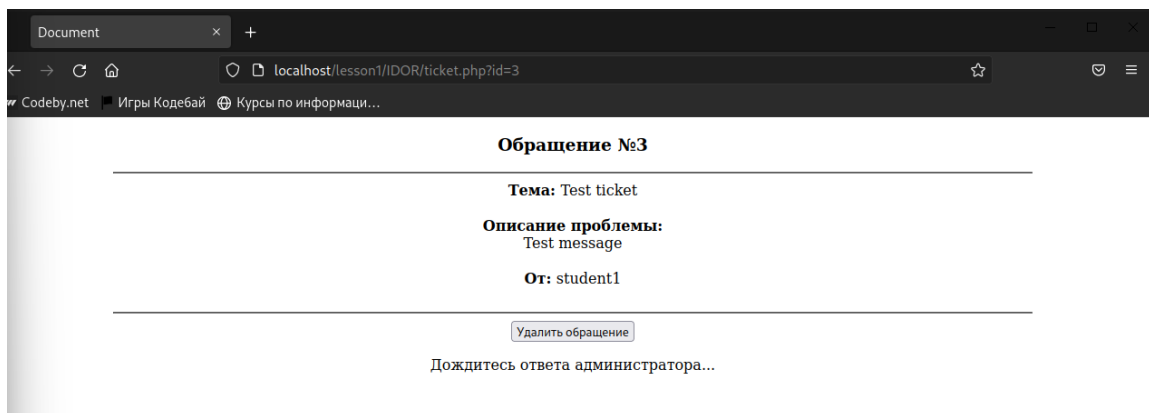


Рисунок 14 — После исправления: своё обращение `id=3` открывается.

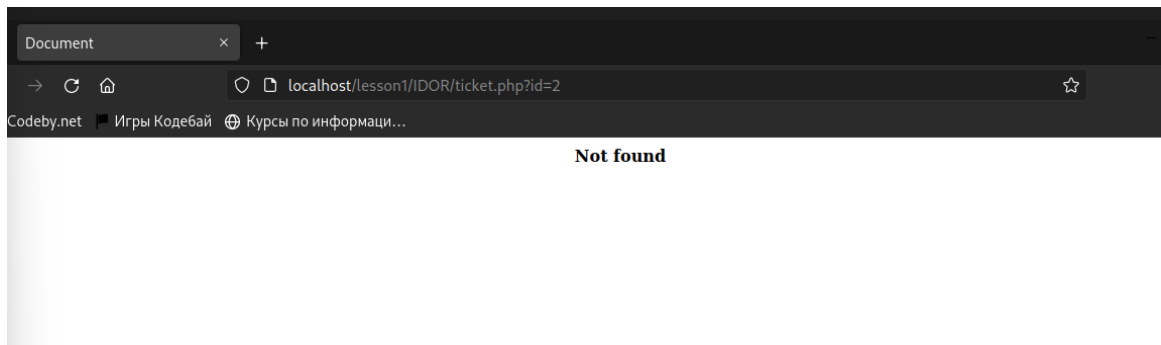


Рисунок 15 — После исправления: чужое id=2 выдаёт Not found.

Заключение

В практической работе последовательно выполнены проверка среды, исследование Misconfiguration, создание тестового обращения, воспроизведение IDOR, исправление контроля доступа и повторное тестирование. После добавления проверки владельца доступ к чужому обращению был закрыт.